Assignment 2: Firewalls

TNM031 – 2026

Name1: _____

Name2: _____

Firewalls

1. **What are the two characteristics of static packet filter firewalls?**

   1) They look at every packet in isolation, with no memory of earlier packets or of which connection it belongs to. 2) They only look at the IP and TCP/UDP headers (addresses, ports, flags), not at the application content.

2. **How do stateful firewalls work for TCP?**

   The firewall keeps a state table of open connections. When a SYN (connection opening attempt) arrives it is checked against the ACL; if it is allowed, the connection is added to the table. Later packets that match an entry in the table are let through without checking the ACL again. Packets that are neither part of an open connection nor an allowed opening attempt are dropped, so e.g. a stray SYN/ACK from outside is blocked. The entry is removed when the connection closes (FIN/RST) or times out.

3. **Can stateful firewalls maintain state information for connectionless protocols like UDP and ICMP?**

   Yes, sort of. UDP and ICMP have no real connections, but the firewall can treat a request and its reply as a pseudo-connection. When an internal host sends a UDP datagram (e.g. a DNS query) or an ICMP echo request, the firewall records addresses/ports and lets a matching reply back in within a short timeout.

4. **How does a NAT firewall work?**

   When an internal host sends a packet out, the firewall replaces the private source IP and port with its own public IP and a new port, and saves the mapping in a translation table. Replies coming back are translated back to the internal address. This hides the internal addresses from sniffers outside, and an outside host cannot start a connection in, because there is no table entry for it.

5. **Explain application firewall operation.**

   An application firewall (proxy) works at the application layer. The client connects to the proxy instead of the server; the proxy checks the content (commands, URLs, file types, etc.) against its rules and, if OK, opens a separate connection to the server on behalf of the client and relays the data. There is never a direct connection between inside and outside, and the internal IP addresses stay hidden.

6. **If you will proxy four applications, how many proxy programs will you need?**

   Four. Each application (e.g. HTTP, SMTP, FTP, DNS) needs its own proxy program, since the proxy has to understand that specific protocol.

7. **Should the last rule of a screening firewall be Deny All or Permit All? Explain.**

   Deny All. Rules are checked top to bottom, and anything that has not been explicitly allowed should be dropped (default deny). With Permit All, any traffic the admin did not think of, including new attacks, would get through.

8. **You have a rule in your ACL to block a particular type of traffic. However, when you do an audit, you find that the firewall is not blocking this traffic. What is the problem likely to be?**

   The rules are in the wrong order. The firewall uses the first rule that matches, so an earlier, more general permit rule matches the traffic first and the deny rule is never reached. The deny rule has to be moved above the permit rule.

9. **Does this rule set enforce the LiU security policy? Explain.**

```
allow tcp  *:*                -> 130.236.8.134:25
drop  tcp  *:*                -> 130.236.8.134:*
allow tcp  130.236.136.96:*   -> *:*
allow tcp  130.236.136.97:*   -> *:*
...       // one rule per internal IP
drop  *    *:*                -> *:*
```

   No, not fully. The inbound part works: SMTP to 130.236.8.134:25 is allowed, everything else to the mail server is dropped, and other inbound traffic falls through to the final drop.

   The problems are:

   • **Return traffic is blocked.** The allow rules only match packets whose *source* is an internal host. When an internal host opens a connection, the server's replies (SYN/ACK, data) come from outside to the internal host, and no rule allows that, so they hit the last drop rule. Outbound connections therefore cannot actually be established (assuming a stateless packet filter, which this ACL looks like). The same goes for the mail server: replies to its own outbound connections (e.g. delivering mail to other servers) are dropped by rule 2.

   • **Only TCP.** Outbound UDP and ICMP (e.g. DNS, ping) are dropped, although the policy says all outbound connections should be allowed.

   • **Spoofing.** The rules only check the source address, not which interface the packet came in on. An outside attacker can send packets with a spoofed internal source like 130.236.136.96 and they will be allowed to any destination, including internal hosts, which breaks the inbound part of the policy.

   To fix it, use a stateful firewall (or add rules for return traffic), include UDP/ICMP, and add anti-spoofing rules that drop packets from outside claiming an internal source address.